



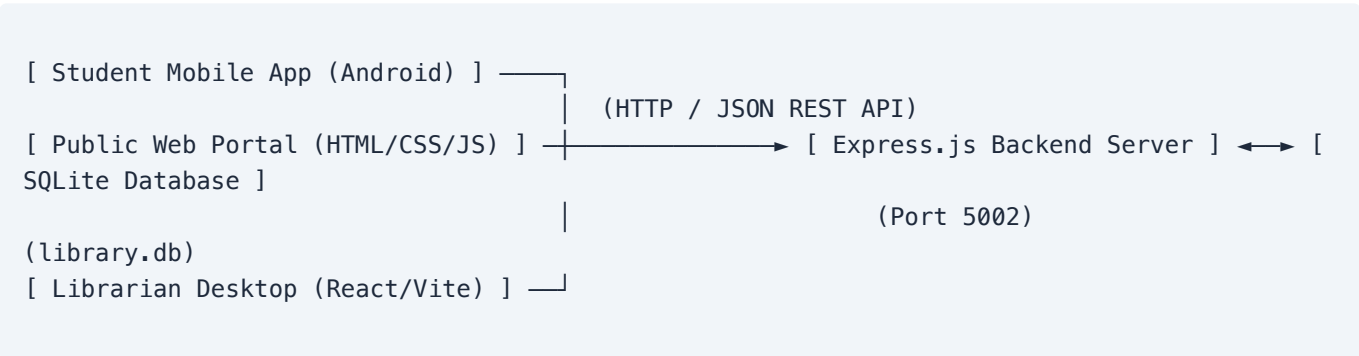
Master Capstone Study Guide: CDM Library System

Colegio de Montalban — Integrated Library Management System Panel Defense Preparation

1. 🚀 30-Second Elevator Pitch (What to say when panel asks: "What is your project?")

"Our Capstone project is the Integrated Library Management System for Colegio de Montalban (CDM). It is a multi-platform solution consisting of an Android Mobile App for students to search books, track due dates, and reserve titles 24/7, a Desktop Admin Panel for librarians to manage books, checkouts, returns, and penalty fines, and a Public Web Portal for live catalog search and app downloads. It eliminates long library queues, prevents late return penalties, and automates physical book inventory management."

2. 🧩 How Everything Works Together (System Architecture)



3. 🛠️ Tech Stack Explained in Simple Terms

Component	Technology	Plain English Explanation
Frontend Framework	React 19 + TypeScript	Powers the interactive Librarian Dashboard UI with strong type-checking to prevent bugs.
Build Tool	Vite 6	Compiles React code for instant browser loading.
Styling & UI	TailwindCSS 4 + Radix UI	Handles layouts, badges, modals, and responsive design.
Charts	Recharts	Generates visual graphs for borrowing trends and book statistics.
Backend Engine	Express.js v5 (Node.js)	Web server handling all API routes (/api/books, /api/auth/login, etc.).
Database	SQLite 3 (better-sqlite3)	Fast file-based relational database storing all data in library.db.

Component	Technology	Plain English Explanation
Security	JWT + PBKDF2 Hashing	Secures login tokens and safely encrypts passwords before saving.
Rate Limiter	Custom In-Memory Limiter	Blocks brute-force logins (15 attempts/15m) and DoS attacks (300 reqs/15m).

4. 🗝️ Core Features & How They Work Behind the Scenes

A. Authentication & Registration

- **Password Verification:** Compares login passwords against PBKDF2 salted hashes safely with `crypto.timingSafeEqual`.
- **24-Hour JWT:** Returns a signed token stored in local storage for authenticating API calls.
- **Admin Approval:** New librarian accounts stay pending until approved by the Head Librarian.

B. Inventory, Loans & Penalties

- **Stock Auto-Decrement:** Borrowing/reserving decreases available copies; returning increases them.
- **Automated Overdue Check:** Compares `due_date` against today; updates status to overdue automatically.
- **Penalty Fine Engine:** Calculates elapsed late days and computes total penalty fees.

5. 🛡️ Security Features (Defense Highlights)

- **PBKDF2 SHA-512 Hashing:** Passwords are never saved in plain text and use 16-byte random salts.
- **Rate Limiting Protection:** 15 attempts/15m on login routes (prevents brute-force) and 300 calls/15m on API routes.
- **SQL Injection Immunity:** Uses `better-sqlite3` parameterized queries with placeholders (?).

6. 🧠 Top Panel Defense Questions & Winning Answers

Q1: Why choose SQLite over MySQL or PostgreSQL?

Answer: "SQLite is lightweight, serverless, zero-configuration, and stores data in a single file (`library.db`). It provides top performance for local campus desktop management without complex server administration."

Q2: How do you prevent SQL Injection attacks?

Answer: "We use parameterized prepared statements in `better-sqlite3`. User inputs are sanitized and passed separately rather than concatenated into raw SQL strings."

Q3: How does the system handle brute-force login attempts?

Answer: "Our Express server uses an `authLimiter` middleware that tracks client IPs. If an IP exceeds 15 login attempts within 15 minutes, it blocks the request immediately with an HTTP 429 response."

Q4: How does the mobile app sync with the librarian dashboard?

Answer: "Both the Android mobile app and librarian React dashboard communicate with the same Express REST API server via JSON. Any transaction made on mobile instantly updates the central SQLite database."